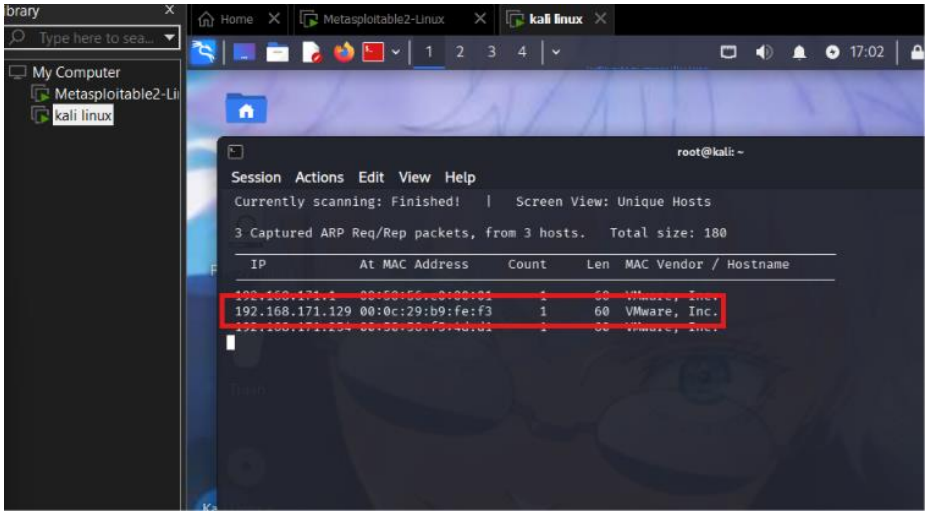
VULNERABILITY ASSESSMENT, PENETRATION TESTING & DIGITAL FORENSIC REPORT

Machine / Target	TechShield Corporate Network (Kali Linux attacker machine and Metasploitable2 target)
Performed by	Nehal Sarode
Assessment Type	Network Vulnerability Assessment, Web Application Security Testing, Password Security & Network Exploitation, and Forensic Evidence Collection
Tools / Services	Kali Linux, Netdiscover, Nmap, DVWA, Hydra, FTP, SSH, dd, md5sum, Autopsy

Machine Description	TechShield Corporate Network assessment — Kali Linux attacker machine used against a Metasploitable2 target, inside an authorized lab/training environment.
Target IP	192.168.171.129
Vulnerability Name	Open Network Services, Union-Based SQL Injection, Stored XSS, RCE via File Upload, Weak FTP/SSH Credentials, and N/A (Forensic Methodology Exercise).
Service / Version	Network Reconnaissance (Nmap), SQL Injection, Stored XSS, RCE via File Upload (DVWA – TCP/80), and Weak FTP/SSH Credentials (TCP/21, TCP/22).
CVSS Score / Severity	9.1 Critical
Attack Vector	Network Reconnaissance (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N); SQL Injection (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H); Stored XSS (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N); RCE via File Upload (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H); Weak FTP/SSH Credentials (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H).
Proof of Concept	**» Network & Service Reconnaissance (Information Disclosure)** **(CVSS 5.3 — Medium)** **STEP 1 – Discover the Target IP using Netdiscover tool**

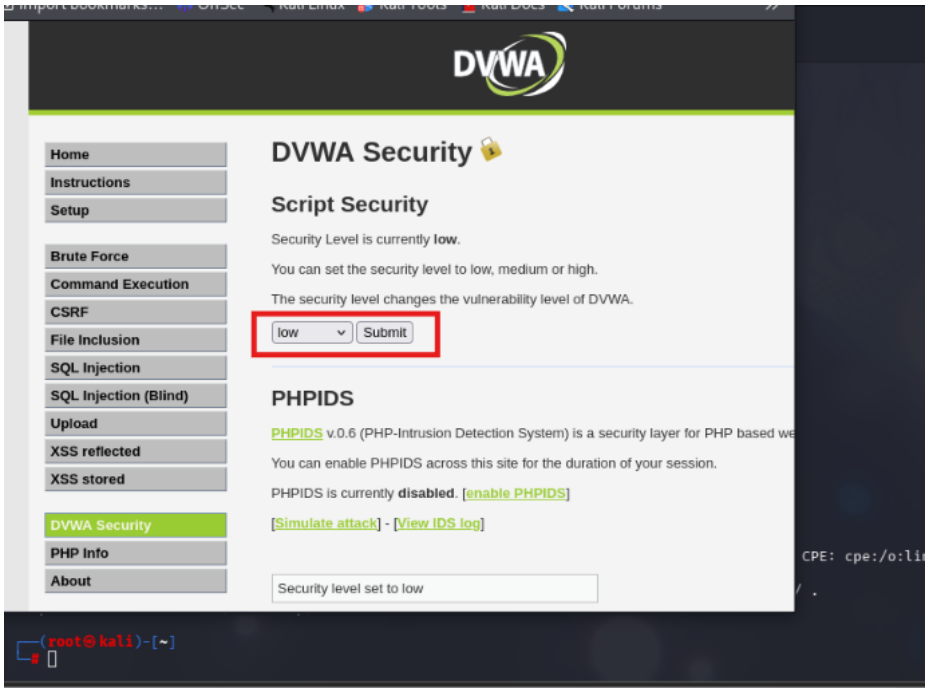


STEP 2 – Scan Target for open ports and services running using Nmap

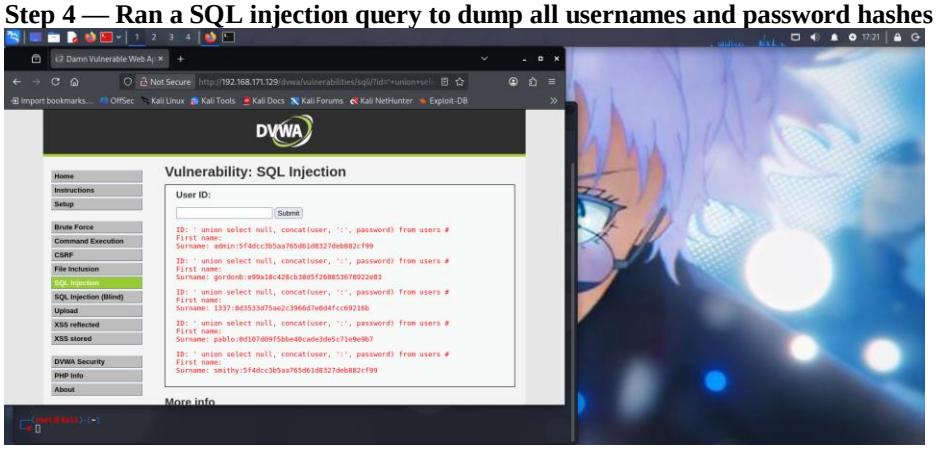


» SQL Injection — Data Theft (DVWA) (CVSS 9.8 — Critical)

Step 3— Opened DVWA and set security level to Low.

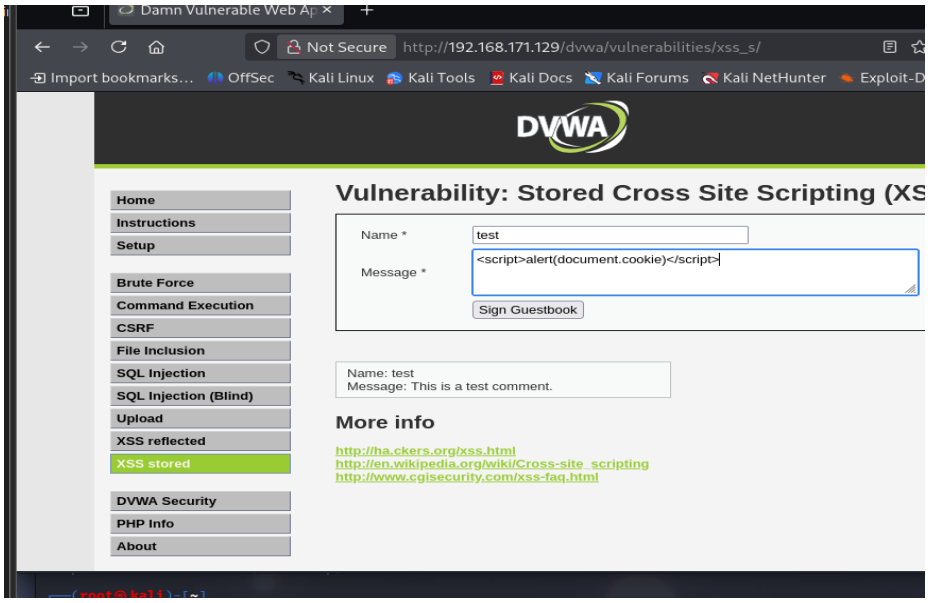


Step 4 — Ran a SQL injection query to dump all usernames and password hashes



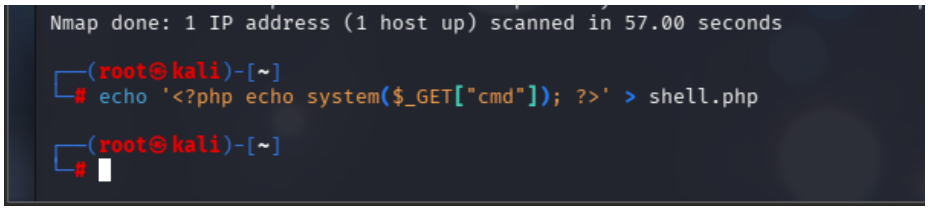
» Stored Cross-Site Scripting (XSS) (CVSS 6.1 — Medium)

Step 5 — Submitted a script payload in the guestbook; it stole the victim's cookie.

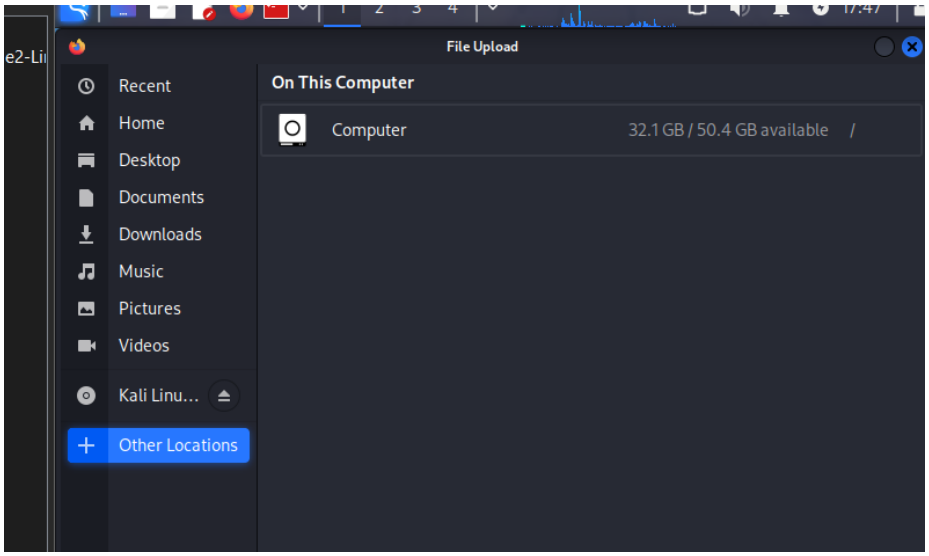


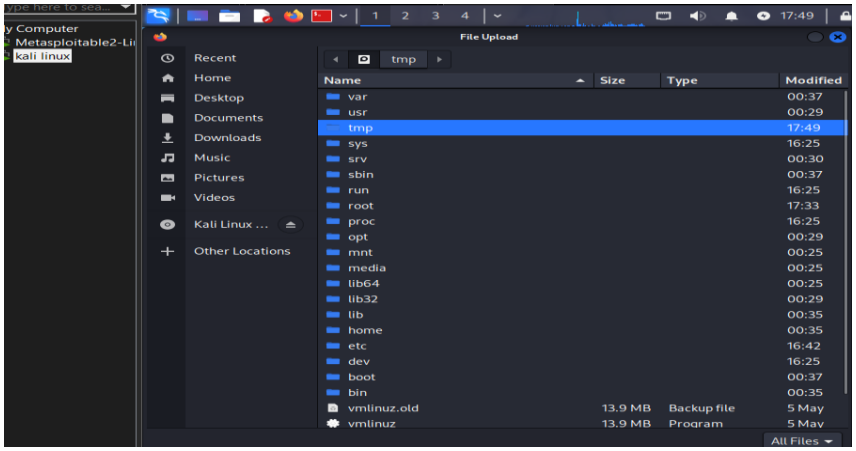
» Remote Code Execution via Unrestricted File Upload (CVSS 9.8 — Critical)

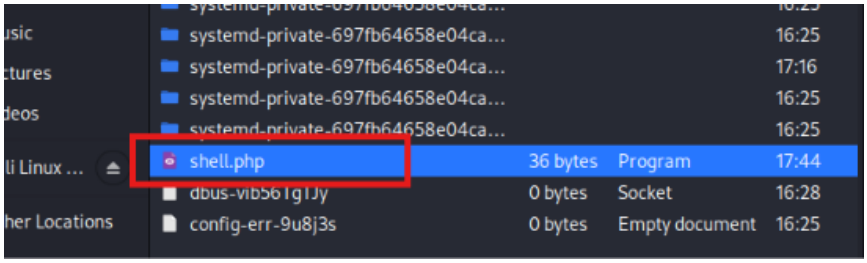
Step 6 — Created a PHP web shell (shell.php).

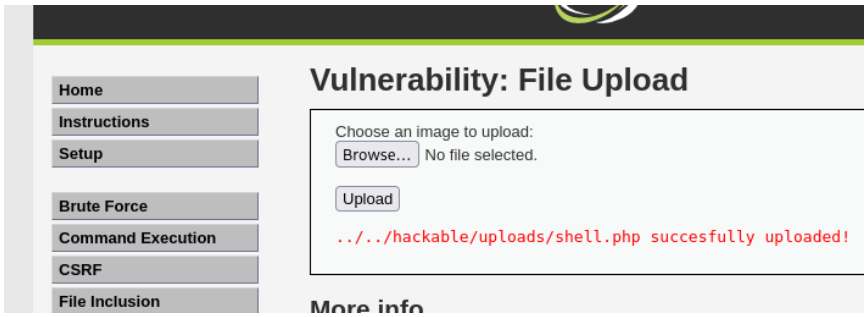


Step 7 — Uploaded shell.php through DVWA's upload page.

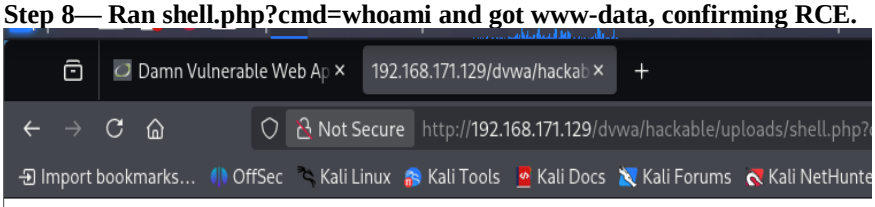

File Upload
Recent
Home
Desktop
Documents
Downloads
Music
Pictures
Videos
Kali Linu...
Other Locations
On This Computer
Computer
32.1 GB / 50.4 GB available


File Upload
Recent
Home
Desktop
Documents
Downloads
Music
Pictures
Videos
Kali Linux ...
Other Locations
tmp
Name
Size
Type
Modified


systemd-private-697fb64658e04ca...
16:25
systemd-private-697fb64658e04ca...
17:16
systemd-private-697fb64658e04ca...
16:25
systemd-private-697fb64658e04ca...
16:25
shell.php
36 bytes
Program
17:44
dbus-vib56Tg1Jy
0 bytes
Socket
16:28
config-err-9u8j3s
0 bytes
Empty document
16:25


Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
Vulnerability: File Upload
Choose an image to upload:
Browse...
No file selected.
Upload
../../hackable/uploads/shell.php succesfully uploaded!
More info

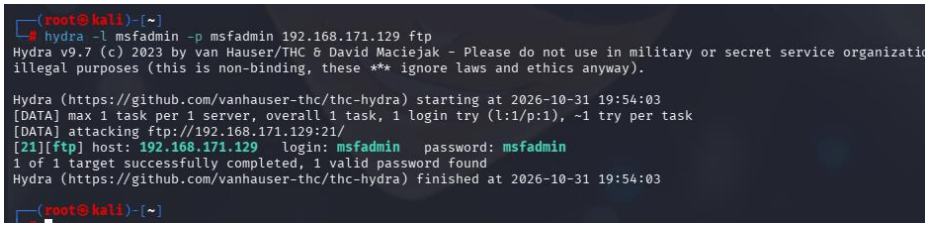
Step 8— Ran shell.php?cmd=whoami and got www-data, confirming RCE.



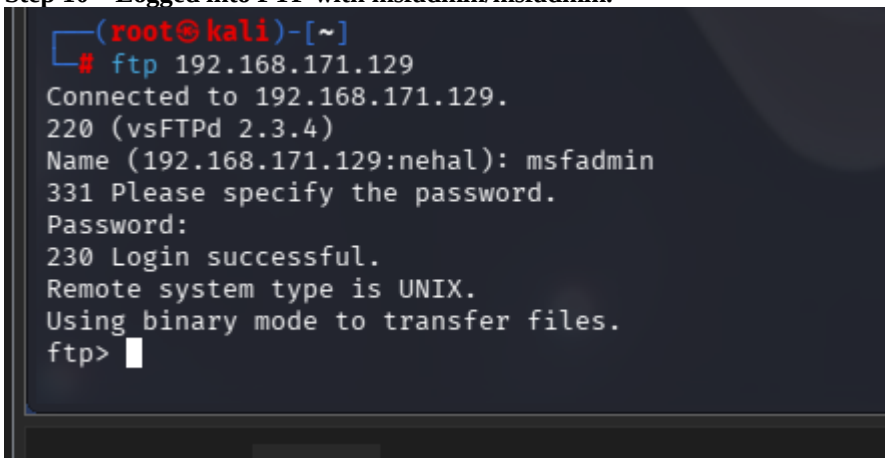
www-data www-data

» Weak / Default Credentials — FTP & SSH (CVSS 9.8 — Critical)

Step 9 — Brute-forced FTP login with Hydra using msfadmin/msfadmin.



Step 10 – Logged into FTP with msfadmin/msfadmin.



Step 11– Logged into SSH with the same weak credentials

```
┌──(root㉿kali)-[~]
└─# ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa msfadmin@192.168.171.129
The authenticity of host '192.168.171.129 (192.168.171.129)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GCiOLuVscegPXLQOsuPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.171.129' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.171.129's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sat Oct 31 07:22:59 2026
msfadmin@metasploitable:~$
```

» Digital Forensic Evidence Collection & Analysis

Step – 12 Created a 50MB evidence file using dd.

```
┌──(root㉿kali)-[~]
└─# dd if=/dev/zero of=~/evidence.img bs=1M count=50
50+0 records in
50+0 records out
52428800 bytes (52 MB, 50 MiB) copied, 0.25364 s, 207 MB/s

┌──(root㉿kali)-[~]
└─#
```

Step 13 — Confirmed the evidence file was created.

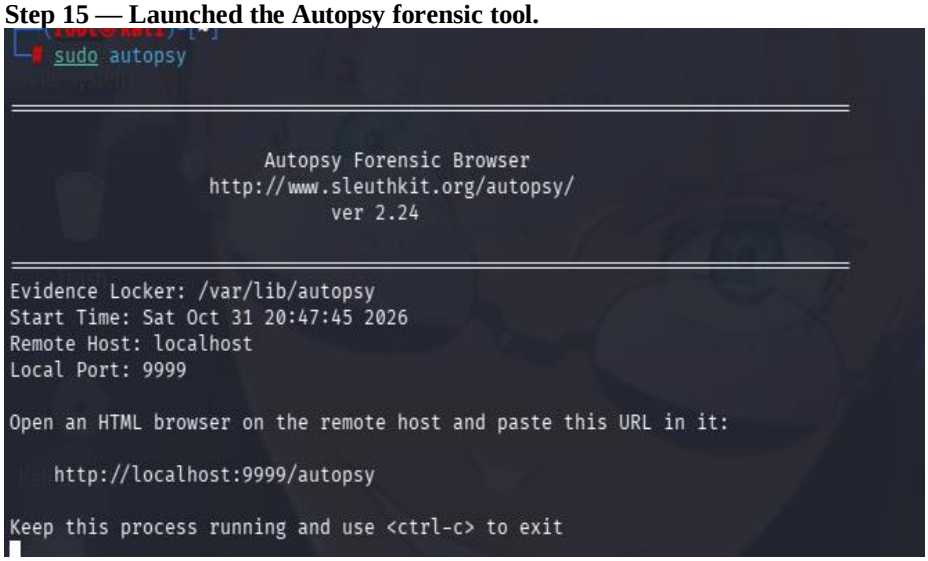
```
┌──(root㉿kali)-[~]
└─# ls -la ~/evidence.img
-rw-rw-r-- 1 root root 52428800 Oct 31 20:41 /root/evidence.img

┌──(root㉿kali)-[~]
└─#
```

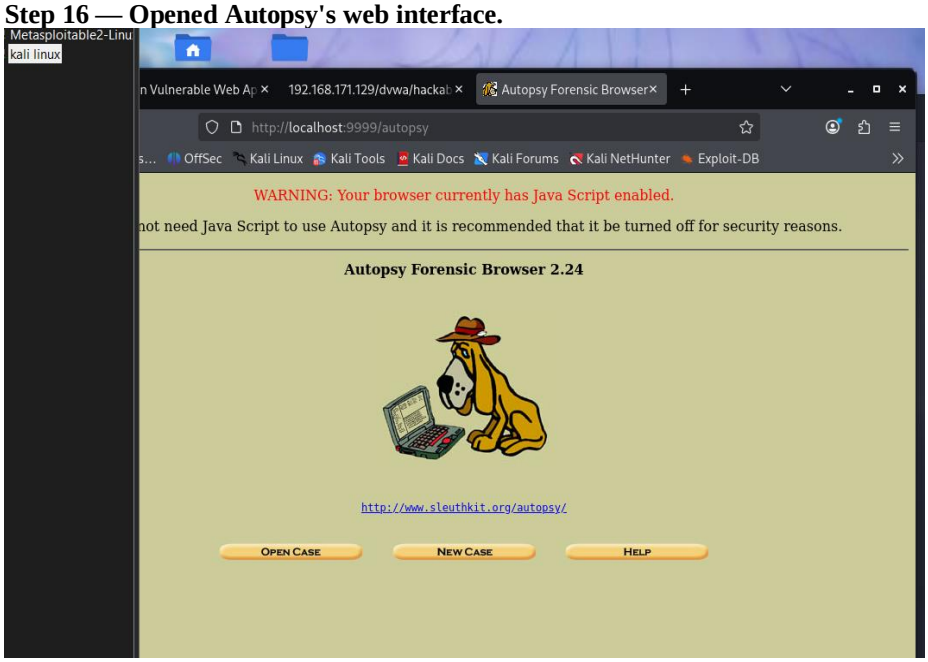
Step 14— Generated the MD5 hash of the evidence file.

```
┌──(root㉿kali)-[~]
└─# md5sum ~/evidence.img
25e317773f308e446cc84c503a6d1f85  /root/evidence.img
```

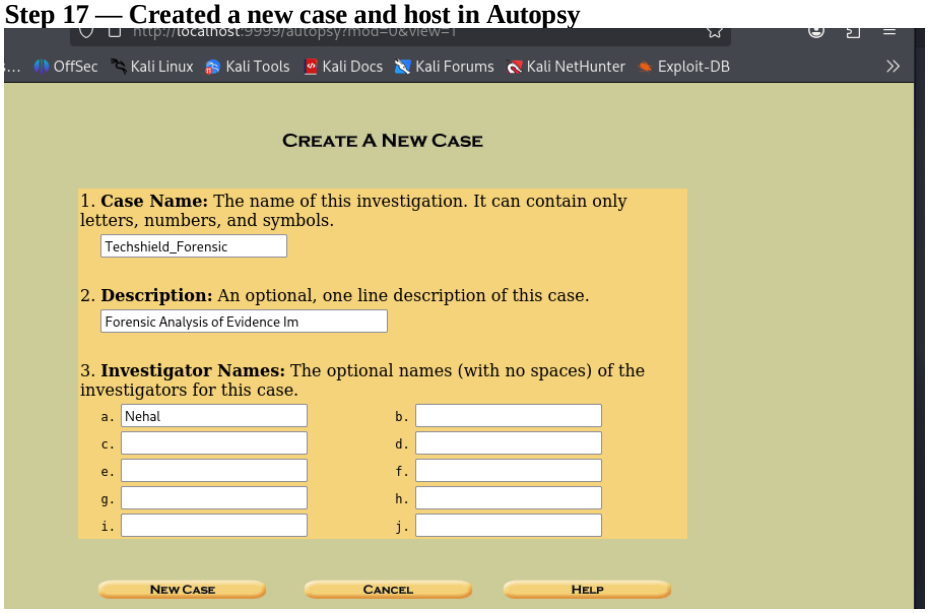
Step 15 — Launched the Autopsy forensic tool.



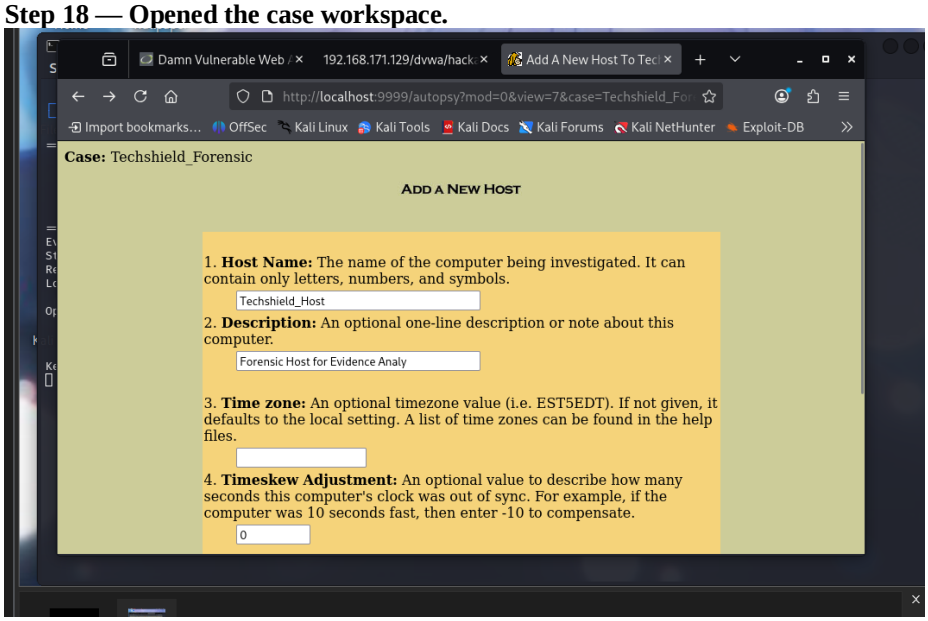
Step 16 — Opened Autopsy's web interface.



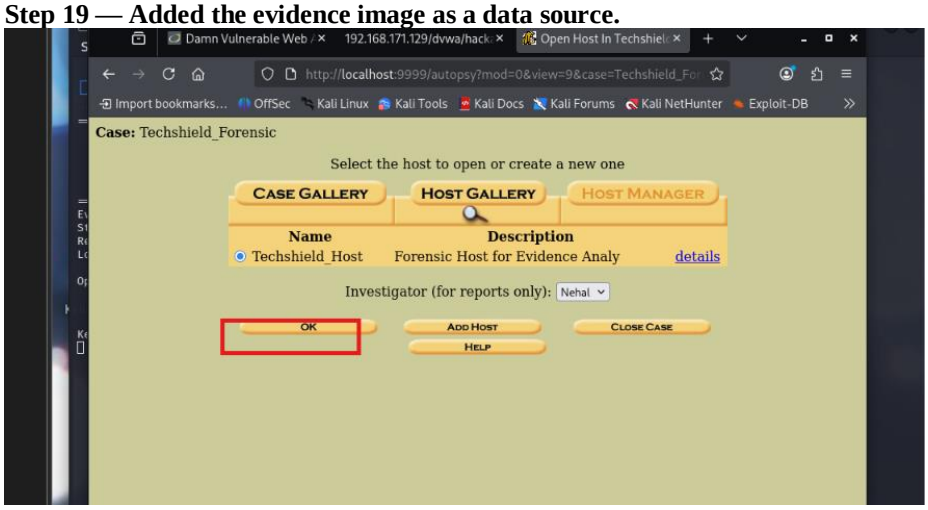
Step 17 — Created a new case and host in Autopsy



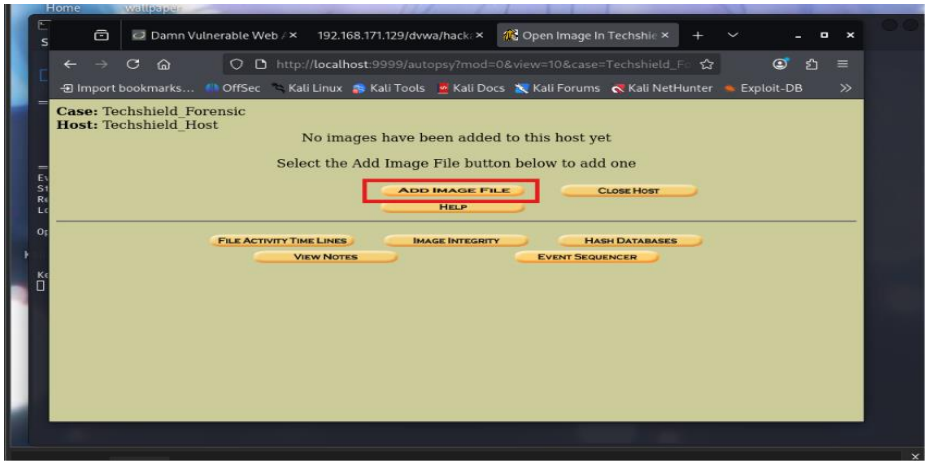
Step 18 — Opened the case workspace.



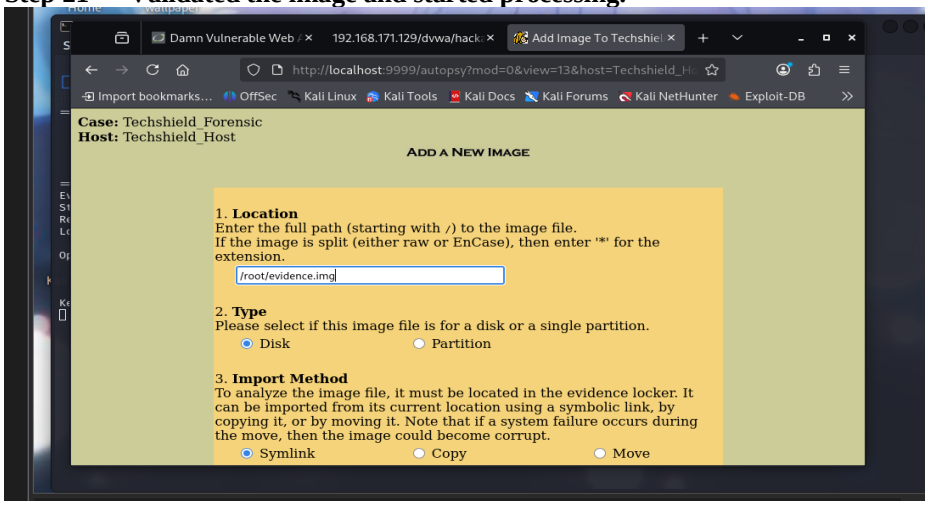
Step 19 — Added the evidence image as a data source.



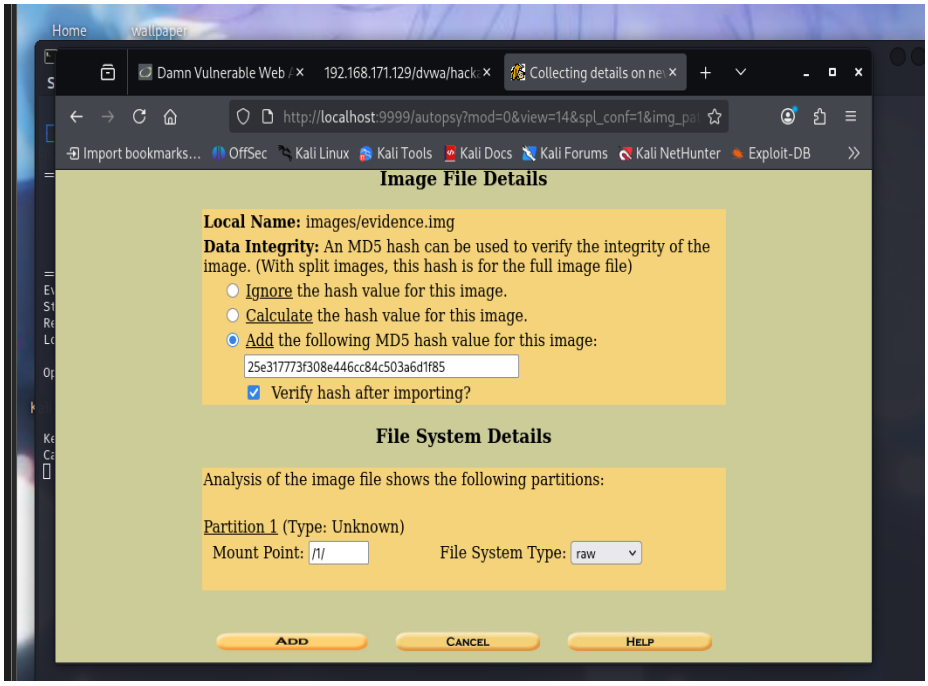
Step 20 — Confirmed the image path and ingest settings.



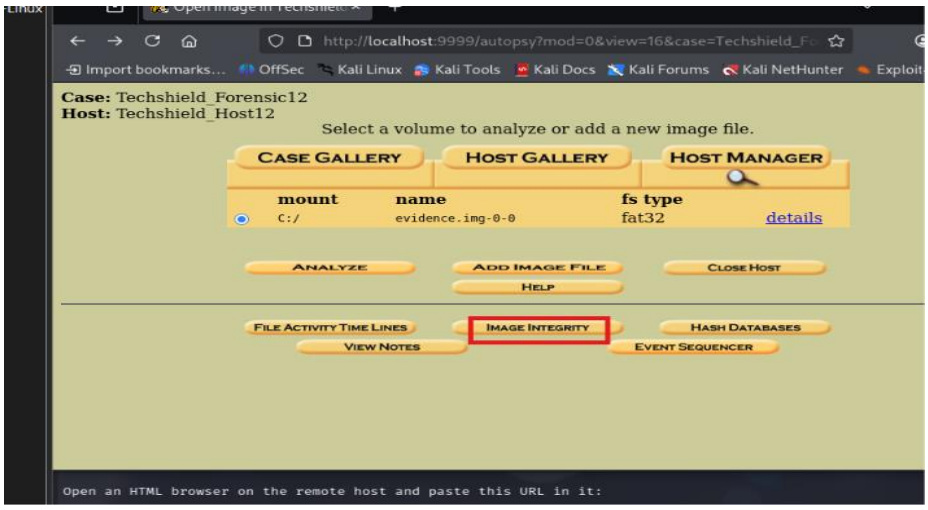
Step 21 — Validated the image and started processing.



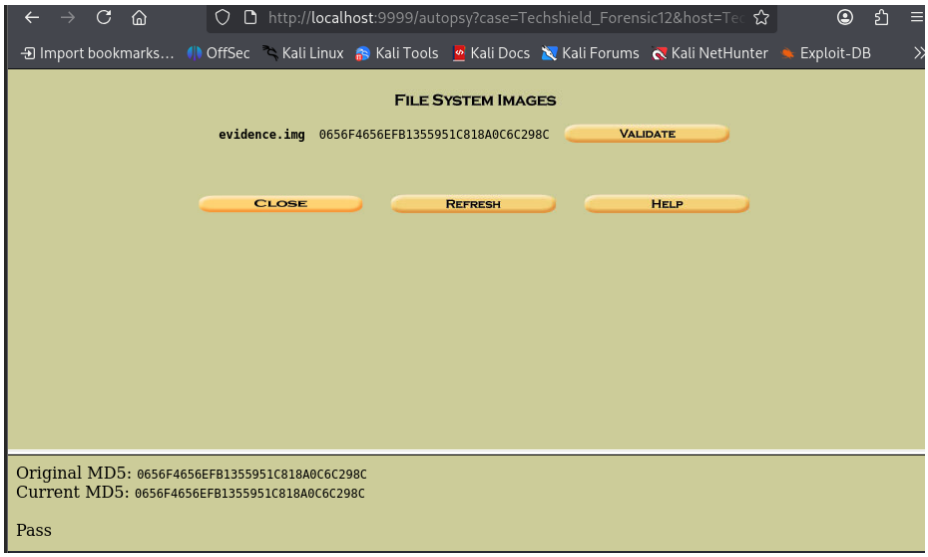
Step 22 — Browsed the file system inside the image.



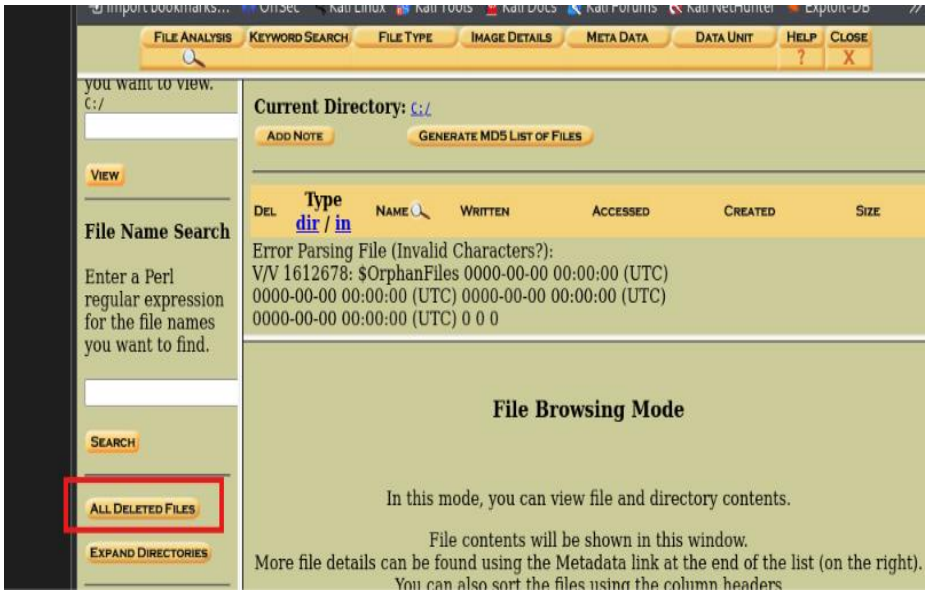
Step 23 — Check Image intergrity



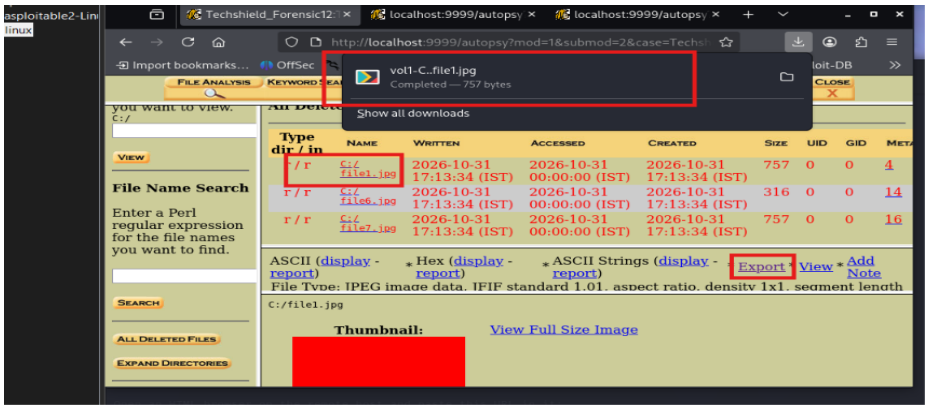
Step 24— Validate evidence hash



Step 25— check all deleted files



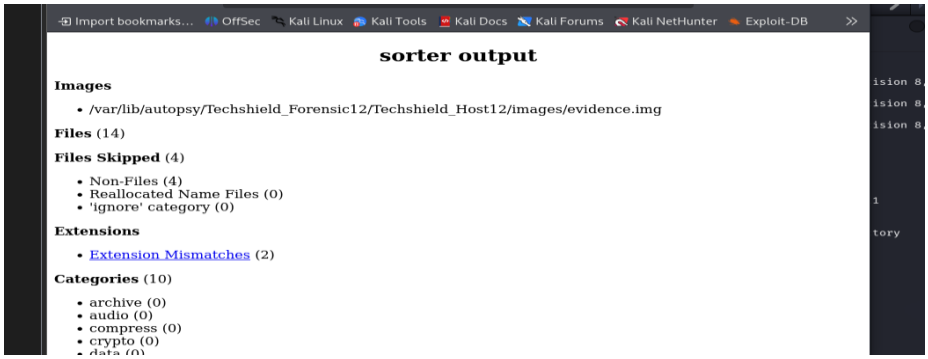
Step 26— Extract all the deleted files



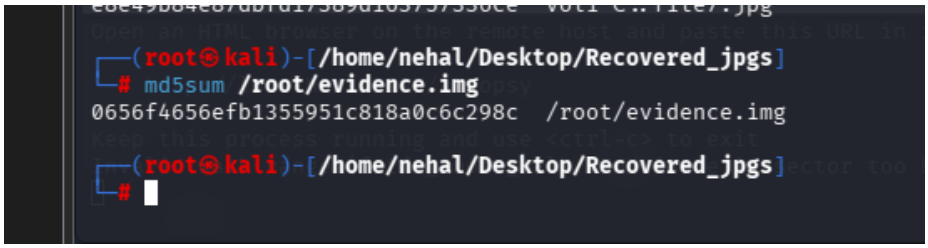
Step 27 – Sorted files by type to catch hidden/renamed files.



Step 28 – Opened the sorter results summary page.



Step 29 – Re-ran MD5 and confirmed the hash still matched.



Impact	• Network Reconnaissance: Reveals active hosts, open ports, and service versions, helping attackers identify potential targets. • SQL Injection: Exposes usernames and password hashes from the application database. • Stored XSS: Executes malicious scripts in visitors' browsers, potentially stealing sessions and hijacking accounts. • Remote Code Execution: Allows attackers to execute operating-system commands through an uploaded PHP file. • Weak FTP/SSH Credentials: Provides unauthorized authenticated access and remote shell access to the target. • Digital Forensics: Demonstrates evidence collection, hash verification, and analysis using Autopsy.
Remediation	• Network Reconnaissance: Close unused ports, configure firewalls, segment networks, and deploy IDS/IPS. • SQL Injection: Use prepared statements, validate inputs, and apply least-privilege database access. • Stored XSS: Sanitize inputs, encode outputs, implement CSP, and use HttpOnly cookies. • Remote Code Execution: Validate uploads, store files outside the web root, and disable script execution. • Weak FTP/SSH Credentials: Remove default accounts, enforce strong passwords, enable account lockout, and use SSH keys.
Reference	• Network Reconnaissance: CWE-200 • SQL Injection: OWASP SQL Injection • Stored XSS: OWASP XSS • Unrestricted File Upload: OWASP File Upload • Weak Credentials: CWE-521 • Digital Forensics: NIST Software Quality